Projet CTF
Compte-rendu Scénario “Work Net”

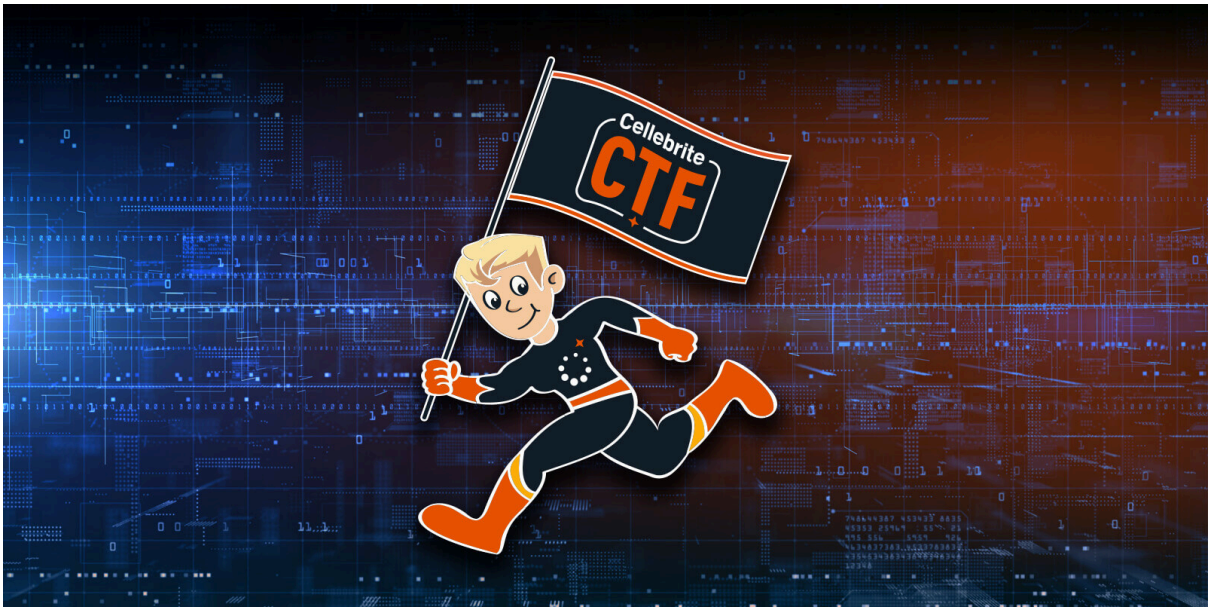


Table des Matières

Introduction **2**
1 - Présentation de l'équipe **3**
2 - Contexte et scénarisation **4**
2.1 - Présentation du contexte 4
2.2 - Scénarisation 5
3 - Objectifs **6**
3.1 - Objectifs principaux 6
3.2 - Objectifs techniques 7
4 - Conception de l'infrastructure **8**
4.3 - Architecture logique 8
4.4 - Architecture physique 9
5 - Défis rencontrés **10**
5.1 - Défis techniques 10
6 - Étapes du CTF **12**
6.1 - Énoncé 12
6.1.1 - Étape 1 12
6.1.2 - Étape 2 12
6.1.3 - Étape 3 13
6.1.4 - Étape 4 13
6.1.5 - Étape 5 13
6.1.6 - Étape 6 13
6.1.7 - Étape 7 13
6.1.8 - Étape 8 14
6.1.9 - Étape 9 14
7 - Procédure de déploiement du scénario **15**
7.1 Instanciation de l'infrastructure 15
7.2 Configuration des machines 15
8 - Conclusion **16**
8.1 Facturation 16
8.2 Retour d'expérience 17

Introduction

Dans le domaine en constante évolution de la sécurité informatique, la création et la participation à des environnements de simulation de cyberattaques sont devenues des aspects cruciaux pour former des professionnels compétents et vigilants. En réponse à cette exigence, notre équipe composée d'étudiants en Master Systèmes de Télécommunications Réseaux et Informatiques (STRI) a entrepris la conception d'un Capture The Flag (CTF), baptisé "Work Net".
Ce projet s'inscrit dans le cadre de notre engagement à fournir une expérience éducative et pratique pour notre dernière année de formation.

"Work Net" a été élaboré pour mettre à l'épreuve les compétences de sécurité informatique des étudiants STRI, les poussant à développer des stratégies de résolution de problèmes, à renforcer leur compréhension des vulnérabilités et à affiner leurs compétences techniques.

Au cours de ce rapport, nous explorerons en détail la conception de "Work Net", en nous penchant sur les choix de conception, les défis spécifiques intégrés, et les objectifs qui ont guidé le processus de création. En outre, nous examinerons comment ce CTF s'accorde aux exigences globales de la cybersécurité au sein de la formation STRI, visant à fournir un challenge ludique en phase avec les réalités du monde professionnel.

À travers "Work Net", notre ambition est donc de contribuer à la formation de futurs étudiants STRI, tout en offrant une expérience qui saura éveiller leur curiosité tout en respectant les standards de notre programme de Master STRI.

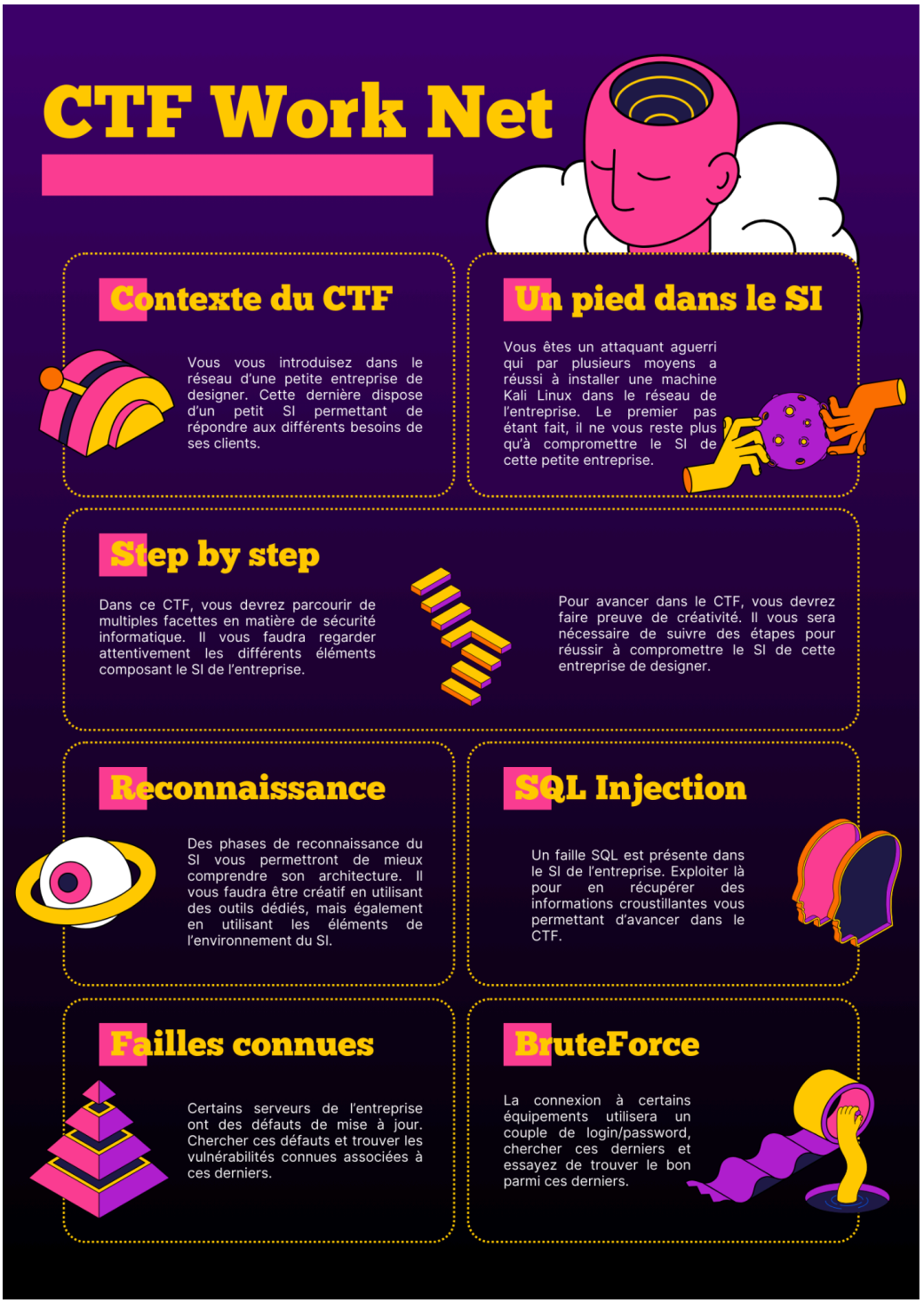
1 - Présentation de l'équipe

Notre équipe est composée de membres ayant, avant STRI, des parcours différents dans le domaine informatique.

Composé de membres venus d'horizons différents, cela nous a permis de nous entraider et de répartir les tâches de façon à exploiter les forces de chacun pour avancer au mieux.

2 - Contexte et scénarisation

2.1 - Présentation du contexte



2.2 - Scénarisation

Notre Capture The Flag (CTF) a été spécialement conçue dans un esprit éducatif et ludique, visant à offrir une expérience immersive pour maîtriser des commandes considérées comme "basiques" dans le domaine de la sécurité informatique.
Notre premier objectif est de fournir un environnement d'apprentissage stimulant, où les participants peuvent acquérir des compétences pratiques tout en s'amusant. Pour cela, nous avons élaboré notre CTF en s'appuyant sur un scénario réaliste qui reflète un cas possible en matière de sécurité informatique.

Au cœur de cette simulation se trouve l'idée de prévenir des failles potentielles en encourageant les participants à explorer et à comprendre les commandes de base utilisées dans le contexte de la sécurité informatique.
Chaque étape de notre CTF est conçue pour mettre en lumière des scénarios réels et des pratiques possibles dans le domaine de la cybersécurité. De la découverte des adresses IP à la manipulation des VLAN, en passant par l'identification de failles de sécurité, notre CTF offre l'opportunité d'acquérir ou de revoir des compétences pratiques tout en résolvant des défis lucratifs.
Nous espérons que cette expérience vous inspirera à approfondir vos connaissances et à développer votre expertise dans le vaste domaine de la cybersécurité.

Bienvenue dans cette aventure captivante où l'apprentissage se mêle à l'amusement, et où la sécurité informatique devient une expérience concrète et enrichissante.

Bonne chance dans votre exploration et que chaque défi relevé soit une victoire pour renforcer votre maîtrise de la sécurité informatique !

Chaque action entreprise au cours de ce CTF est une occasion d'apprentissage, soulignant l'importance de la prévention des failles et de la maîtrise des compétences fondamentales en sécurité informatique.

3 - Objectifs

3.1 - Objectifs principaux

Les objectifs principaux nous ont aidé à cadrer notre travail dès le départ afin de construire notre CTF dans les meilleures conditions possibles.

- **Axe du scénario** : Notre objectif est de concevoir un CTF qui soit assez réaliste. C'est-à-dire qu'il puisse correspondre à un scénario d'attaque que l'on peut retrouver dans le monde actuel. Il fallait donc un scénario qui puisse également parler aux étudiants de STRI, assez réaliste, tout en étant réalisable en un temps assez court. Notre choix à donc été de partir sur un contexte d'intrusion dans une PME avec l'inclusion d'un Active Directory, qui est un élément central et critique de toute entreprise de nos jours.

- **Répartition équitable de la charge de travail et gestion du projet** : Dès le départ nous avons établi des rôles permettant de mettre en commun les compétences et les forces personnelles de chacun.
  Voici la répartition des tâches au sein de notre équipe :



CTF - Scénario 1

Use this template to stay on top of your project tasks and progress.

Supervision des tâches

Nom	Statut	Priorité	Date Created	Date Fin
Mise en place AD	COMPLETED	1. HIGH	25 septembre à 10:22	03 décembre
Mise en place BD	COMPLETED	1. HIGH	02 octobre à 08:29	09 octobre
Plan adressage	COMPLETED	1. HIGH	25 septembre à 10:14	25 septembre
Configuration Serveur Web	COMPLETED	2. MEDIUM	25 septembre à 10:14	09 octobre
Configuration Switch	COMPLETED	1. HIGH	25 septembre à 10:14	09 octobre
Configuration Serveur FTP	COMPLETED	2. MEDIUM	25 septembre à 10:14	09 octobre
Création Poste Utilisateur	COMPLETED	2. MEDIUM	25 septembre à 10:24	03 décembre
Configuration Security Onion	COMPLETED	2. MEDIUM	02 octobre à 08:37	02 octobre
Scénarisation	COMPLETED	2. MEDIUM	06 novembre à 09:16	11 décembre
Mise en place de l'infra	COMPLETED	1. HIGH	15 décembre à 08:00	14 décembre
Création des playbook	COMPLETED	1. HIGH	15 décembre à 08:00	14 décembre
Réalisation CTF Note	COMPLETED	2. MEDIUM	15 décembre à 08:02	14 décembre
Rapport	COMPLETED	2. MEDIUM	15 décembre à 08:02	14 décembre
Poster	COMPLETED	3. LOW	15 décembre à 08:02	10 décembre

3.2 - Objectifs techniques

Sur le plan technique, nos objectifs pour "Work Net" ont gravité autour d'un axe central : l'établissement de notre environnement.
Chacun de ces objectifs ont pour but d'assurer la solidité et la cohérence de notre projet.

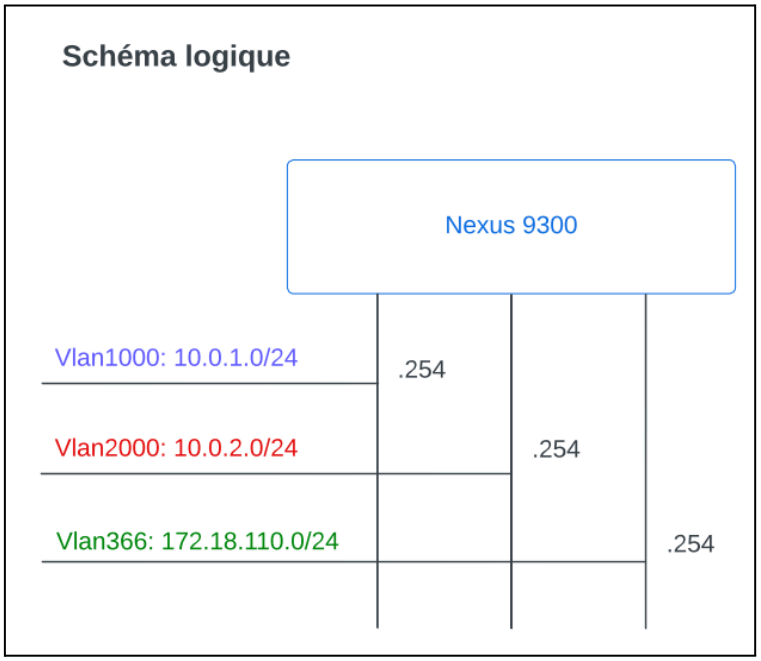
Tout d'abord, nous avons décidé de mettre en place une infrastructure basée sur un écosystème fermé de machines virtuelles. L'écosystème est composé d'un serveur Web, un serveur FTP vulnérable et le serveur AD de l'entreprise, lui aussi vulnérable. Chacun de ces éléments a ses spécificités et ses propres défis, nécessitant une compréhension approfondie pour garantir une mise en place efficace. Cette phase a été l'occasion de se replonger dans ces environnements, offrant une opportunité d'approfondir nos compétences.

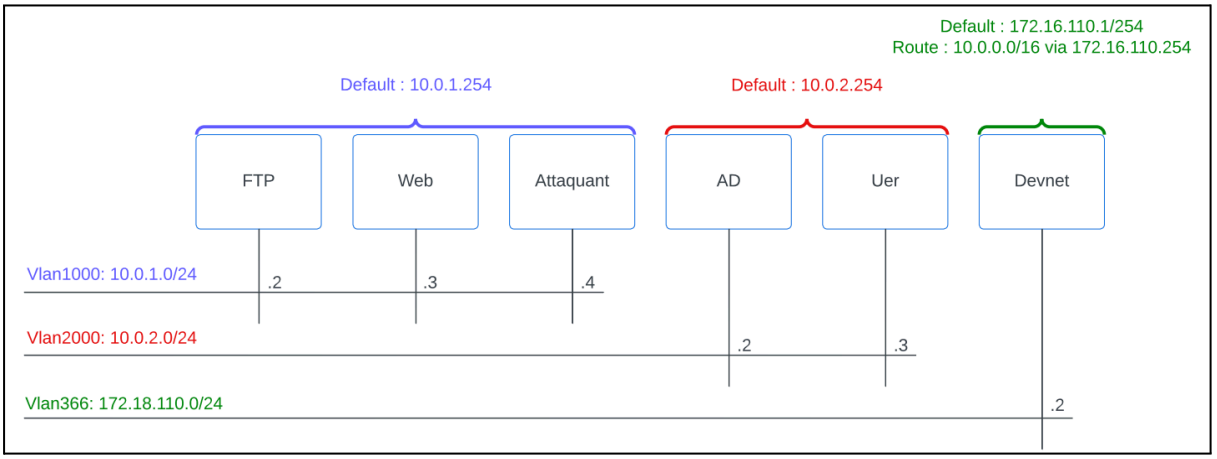
Un autre objectif crucial était la mise en place de failles maîtrisées et la compréhension approfondie de celles-ci. Cette étape a exigé une maîtrise pointue de notre architecture afin d'éviter toute vulnérabilité non intentionnelle qui aurait pu compromettre l'intégrité et la sécurité de notre scénario.

Enfin, le dernier objectif technique fondamental était la création d'un environnement automatisé et reconstructible. L'objectif était de garantir la reproductibilité du scénario sans perte de temps, permettant ainsi une flexibilité maximale pour sa répétition à la demande. Cette automatisation vise à assurer une constance dans la qualité de l'expérience, tout en facilitant les tests et les ajustements ultérieurs.

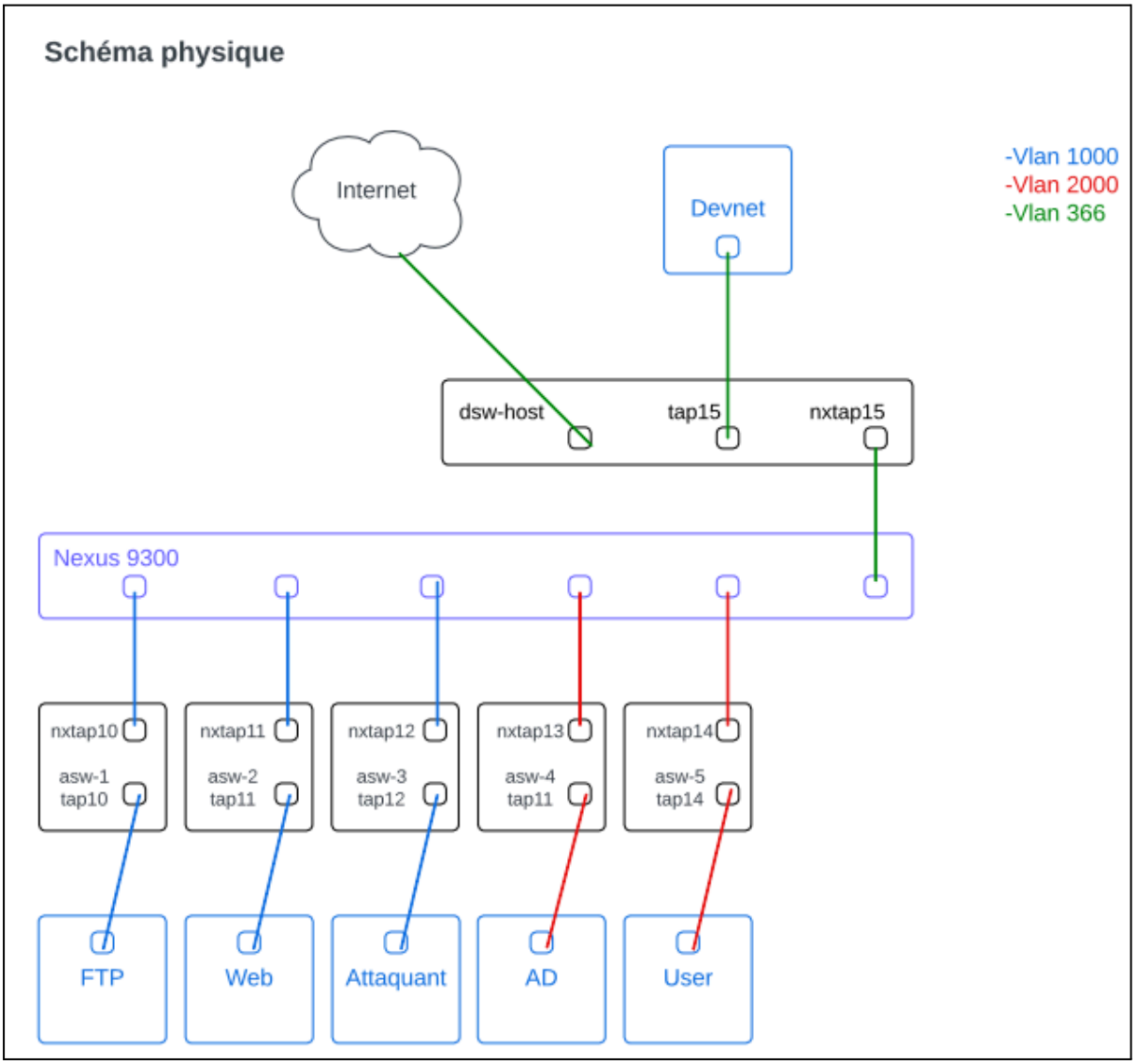
4 - Conception de l'infrastructure

4.3 - Architecture logique





4.4 - Architecture physique



5 - Défis rencontrés

5.1 - Défis techniques

Au cours de la conception de notre CTF "Work Net", nous avons été confrontés à des défis techniques stimulants qui ont mis à l'épreuve notre compréhension des réseaux, de la sécurité informatique et de la configuration de serveurs. Ces défis ont également été l'occasion de développer des solutions créatives pour surmonter les obstacles rencontrés.

Intégration réseau sur l'infrastructure existante :
L'un des principaux défis techniques a été l'intégration du CTF sur l'infrastructure existante STRI, en permettant aux machines virtuelles (VMs) de communiquer avec Internet depuis le réseau derrière le switch. Le besoin supplémentaire était d'autoriser la VM de management à lancer des playbooks directement sur les VMs du CTF tout en venant couper ce lien de management au démarrage du CTF afin de garantir son bon déroulement.

Solutions essayées :

1. **Mise en place d'une route par défaut vers la passerelle dans le VLAN 366** :
   - Problème : La passerelle ne connaissait pas le réseau des VMs derrière le switch, entraînant un échec de la communication.

2. **Utilisation de NAT (Network Address Translation) et PAT (Port Address Translation) sur le switch** :
   - Problème : Le switch n'était pas conçu pour cela, entraînant une latence importante et des problèmes de passage de certains paquets.

3. **Déport du PAT sur une VM CSR1000v** :
   - Problème : Bien que cela fonctionnait pour l'accès à Internet et les pings, le SSH ne fonctionnait pas en raison de problèmes liés à l'adresse IP NAT.

Solution actuelle :
- Les fonctions de NAT ont été déportées directement sur la VM de management. Bien que cette solution puisse ne pas être optimale, elle a résolu les problèmes rencontrés et permet l'exécution des tâches spécifiques prévues en Ansible.

Automatisation de l'attribution d'une interface active sur les VMs :
Une autre problématique pour instancier notre CTF était que pour utiliser Ansible afin de déployer nos services, nous avions besoin que les VMs soient accessibles via le protocole SSH. Le problème c'est qu'en démarrant les images de VMs vierges, elles n'avaient aucune interface configurée. Nous devions donc trouver un moyen autre qu'Ansible afin de déployer nos VMs avec une interface de gestion afin qu'Ansible puisse, dans un deuxième temps, instancier les services.

Solution adoptée :

- Nous avons donc décidé d'utiliser la solution Virt-Customize, ce qui nous permet de modifier les images pour passer des commandes afin de configurer cette interface de gestion et attribuer une IP au premier démarrage de la VM.

Configuration du serveur Active Directory (AD) :
Un autre défi majeur s'est présenté lors de la configuration du serveur Active Directory, où l'idée initiale d'utiliser le token impersonation pour créer une faille s'est avérée trop complexe à mettre en œuvre dans le temps que nous avions. Nous avons alors opté pour une approche plus adaptée basée sur le contournement de l'authentification Kerberos.

Solution adoptée :

- Nous avons choisi de contourner l'authentification Kerberos, en exploitant les vulnérabilités associées à cette méthode d'authentification. Cela a impliqué une analyse fine de la configuration du réseau et l'identification d'exploits potentiels. Cette décision a permis de simplifier la conception tout en maintenant la pertinence du scénario.

En conclusion, ces défis techniques ont été des opportunités précieuses d'apprentissage, nous poussant à repenser nos approches et à trouver des solutions adaptées. Chaque obstacle a renforcé notre compréhension des concepts clés de la sécurité informatique, renforçant ainsi la qualité de notre CTF "Work Net".

6 - Étapes du CTF

6.1 - Énoncé

6.1.1 - Étape 1

Bienvenue dans ce CTF dont le but est de simuler une attaque réseau et de vous encourager à découvrir et à exploiter les vulnérabilités de sécurité.

Votre première mission est cruciale : identifiez le nombre de machines présentes, autre que la vôtre, au sein du réseau.

Pour cela, veuillez vous connecter à l'hyperviseur en IPv6 ou par le VPN de Monsieur Latu.
Après cela, faites un port forwarding sur le port 5912 en localhost.
Ouvrir Remote viewer ou tout autre logiciel qui prend en charge le protocole SPICE.

Dans l'adresse, renseigner : spice://localhost:5912
Identifiant:
Mdp:

Explorez votre environnement afin de trouver le nombre de machines qui est la réponse à ce challenge. Bonne chance dans cette première phase palpitante !

Flag n°1 : **3**

1. Aide : Effectuez une énumération des machines présentes sur le réseau, via une application comme Nmap...

6.1.2 - Étape 2

La première étape franchie, fouillez désormais le serveur FTP qui peut contenir des informations pour valider ce challenge mais qui pourront également vous servir au cours de ce CTF…

Flag n°2 : " **keep_up_to_date_our_internal_applications:) "**

1. Aide : Le serveur FTP fait tourner l'application vsFTPD sous la version 2.3.4, celle-ci contient peut être une vulnérabilité exploitable…
2. Aide : La vulnérabilité du serveur FTP a pour ID la CVE-2011-2523...

6.1.3 - Étape 3

Vous devez maintenant vous aventurer dans la tentative d'accès au switch. Fouillez et exploitez la machine restante du réseau pour trouver des informations vous permettant de pouvoir vous y connecter.

Une fois que vous aurez réussi à pénétrer dans le switch, votre mission ne fera que commencer.

Flag n°3.1 : **User/Password**

1. Aide : Le serveur web présente un formulaire de connexion, une vulnérabilité bien connue est très certainement exploitable…
2. Intéressez vous à l'injection SQL...

Flag n°3.2 : **G9T&8msENW&r**

6.1.4 - Étape 4

Votre périple continue avec une nouvelle tâche cruciale : découvrez quel autre sous-réseau est configuré au sein de l'infrastructure.
Plongez-vous dans la configuration du réseau avec soin, car c'est là que réside l'information vitale dont vous avez besoin.
Format du flag : X.X.X.X/X

Flag n°4 : **10.0.2.0/24**

6.1.5 - Étape 5

En ayant la main sur le switch, trouvez une solution pour identifier combien de machines sont présentes au sein du vlan 2000.

Flag n°5 : **3**

1. Aide : Il faudrait changer de Vlan via la configuration du switch
2. Aide : L'interface physique te concernant est la Ethernet Gigabit 1/3...

6.1.6 - Étape 6

Trouvez le nom de domaine associé à l'Active Directory (AD) interne de l'entreprise.

Flag n°6 : **saguaro.com**

1. Aide : Le paramètre -sV de l'application Nmap peut aider à trouver la réponse...

6.1.7 - Étape 7

Trouvez un moyen de découvrir un nom d'utilisateur valide au sein de l'Active Directory (AD) interne de l'entreprise…

Flag n°7 : **Asdek**

1. Aide : La liste d'utilisateurs trouvée sur le serveur FTP peut être utile...
2. Aide : La vulnérabilité à exploiter auprès de l'Active Directory (AD) concerne le protocole Kerberos...
3. Aide : L'attaque à effectuer se nomme Kerberoasting...
4. Aide : Le binaire nommé kerbrute_linux_amd64, se trouvant sur le Bureau de votre machine Kali Linux, peut vous aider à essayer les noms d'utilisateur sous forme d'un bruteforce...

6.1.8 - Étape 8

Un nom d'utilisateur valide trouvé, tentez maintenant de découvrir le mot de passe associé à celui-ci...
Le flag à rendre est le hash du mot de passe trouvé.

Flag n°8 : Le hash "**$krb5asrep$23$Asdek@SAGUARO.COM**"

1. Aide : Le binaire nommé impacket-GetNPUsers se trouvant sur ta machine Kali Linux peut t'aider à trouver le hash associé à l'utilisateur...

6.1.9 - Étape 9

Cassez le hash trouvé précédemment afin d'avoir celui-ci en clair.

Flag n°9 : Mot de passe "**Bikini1**"

1. Aide : Utilisez une application de cassage de hash comme hashcat ou encore John the Ripper, tous deux disponibles sur votre machine Kali Linux...

7 - Procédure de déploiement du scénario

Afin de pouvoir permettre la rejouabilité du scénario, nous avons développé des scripts Ansible, au nombre de deux.

7.1 Instanciation de l'infrastructure

Le premier script, développé en langage Bash, nous permet d'instancier l'ensemble des VM qui composent notre scénario. Ainsi, ce dernier nous permet de démarrer les VM avec une préconfiguration réseau, dont l'adresse IP, la passerelle par défaut, le numéro de VLAN, etc pour pouvoir ensuite enchaîner avec la partie déploiement.

7.2 Configuration des machines

Le second script, développé en YAML dans le cadre d'Ansible, nous permet de déployer et de configurer l'ensemble des services nécessaires au fonctionnement de notre scénario une fois les VM instanciées, par exemple télécharger et configurer l'application vsFTPD du serveur FTP pour mettre en place la vulnérabilité ou encore mettre en place les dockers pour le serveur web de l'infrastructure.

Pour ce faire, nous avons mis en place deux répertoires GitLab, l'un pour la partie instanciation, et l'autre pour la partie déploiement.
Les liens, à travers lesquels retrouver l'ensemble du code source de nos procédures de déploiement, se trouvent à l'adresse suivante :

8 - Conclusion

8.1 Facturation

Afin de faire un point global sur le temps de travail de l'équipe et pour faire suite à l'évolution de notre planification de départ, présentée partie 3.1, du point de vue facturation au client, voici ce qu'il en est

Tâche	Nombre de ressources	Nombre d'heures estimées
Recherche du scénario	5	5
Planification des tâches	1	1
Mise en place du plan d'adressage	2	0.5
Mise en place de l'infrastructure réseau	3	30
Mise en place du serveur Web	2	5
Mise en place du serveur FTP	1	3
Mise en place du serveur AD	2	5
Mise en place de la machine attaquant	1	1
Mise en place du poste utilisateur	2	1
Développement des playbook et scripts	2	20
Scénarisation des challenges avec CTFd	3	6
Réalisation du poster	1	1
Réalisation du compte rendu	5	12
Total		90.5

La création de notre scénario, en passant par la planification jusqu'à l'automatisation et la documentation de ce dernier, est estimée à plus de 90 heures de travail, comptant 5 ressources.

8.2 Retour d’expérience

Le projet “Work Net” incarne notre volonté de participer à la continuité de STRI en fournissant une expérience éducative immersive et pratique pour les promotions à venir.

"Work Net" a été conçu pour tester les compétences en sécurité informatique des étudiants, les poussant à développer des stratégies de résolution de problèmes, à approfondir leur compréhension des vulnérabilités, et à perfectionner leurs compétences techniques. Ce rapport détaille la réalisation de ce CTF, mettant en lumière les choix de conception, les défis rencontrés, et les objectifs sous-jacents qui ont guidé notre processus de création.

Au-delà des aspects techniques, notre équipe a également établi des objectifs personnels visant à favoriser une collaboration efficace et à enrichir notre palette de compétences. La répartition équitable des tâches, le développement de nouvelles compétences, et l'accent sur les savoir-être tels que la communication et la rigueur ont été au cœur de notre démarche.

Les défis techniques n'ont pas manqué au cours de ce projet, mettant à l'épreuve notre détermination et notre capacité à trouver des solutions créatives. Des problématiques liées à la configuration du serveur Active Directory ou aux défis réseau complexes ont été des opportunités pour progresser.

En conclusion, nous sommes fiers de présenter ce CTF comme fruit de notre collaboration et de notre résilience face aux défis. Ce projet restera une référence dans notre fin de parcours académique, nous laissant avec des compétences affinées, des souvenirs marquants, et la certitude que la sécurité informatique est un domaine où l'apprentissage est infini et la collaboration essentielle.